

MODULE 3.2

Access Control Concepts

Network Defense | Cisco Networking Academy

Prepared by: Kudzaishe Majeza

Cisco Networking Academy | 2026

Topics Covered:

3.2.1 • Zero Trust Security

3.2.2 • Access Control Models

3.2.3 • Network Access Control (NAC) Systems

3.2.1 Zero Trust Security

A comprehensive approach to securing all access across networks, applications, and environments

The Zero Trust Principle

- "Never trust, always verify." — Assume zero trust any time someone or something requests access to assets.
- A zero trust security framework helps prevent unauthorized access, contain breaches, and reduce the risk of an attacker's lateral movement through a network.
- Protects the three areas of the organization: Workforce, Workloads, and Workplace.

Traditional vs Zero Trust Perimeter

- Traditional: The network edge (perimeter) separated trusted (inside) from untrusted (outside).
- Zero Trust: Any place where an access control decision is required is considered a perimeter.
- A user who authenticated successfully is NOT automatically trusted to access another resource.
- Users may need to authenticate multiple times, in different ways, to access different layers.

Zero Trust — The Three Pillars

Zero trust addresses security across the entire organization through three interconnected pillars

Workforce

- People — employees, contractors, partners, and vendors — who access work applications using personal or corporate-managed devices.
- Ensures only the right users and secure devices can access applications, regardless of location.

Workloads

- Applications running in the cloud, data centers, and other virtualized environments that interact with one another.
- Focuses on secure access when an API, a microservice, or a container is accessing a database within an application.

Workplace

- Secure access for any and all devices — including IoT — that connect to enterprise networks.
- Examples: user endpoints, servers, printers, cameras, HVAC systems, kiosks, infusion pumps, industrial control systems, and more.

3.2.2 Access Control Models

Understanding these models helps analysts identify how attackers can break access controls

Discretionary Access Control (DAC)

- Least restrictive model — allows users to control access to their own data as owners of that data.
- May use ACLs or other methods to specify which users or groups of users have access.

Mandatory Access Control (MAC)

- Applies the strictest access control — typically used in military or mission-critical applications.
- Assigns security level labels to information (e.g., Top Secret, Secret, Confidential).
- Users are granted access based on their security level clearance.

Role-Based Access Control (RBAC)

- Access decisions are based on an individual's roles and responsibilities within the organization.
- Different roles are assigned security privileges; individuals are assigned to RBAC profiles.
- Roles may include different positions, job classifications, or groups of job classifications.
- Also known as non-discretionary access control.

Access Control Models (continued)

ABAC, Rule-Based, TAC, Least Privilege, and Privilege Escalation

Attribute-Based Access Control (ABAC)

- Allows access based on attributes of the object (resource) to be accessed, the subject (user) accessing the resource, and environmental factors.
- Environmental factors include: time of day, location, device type, and more.

Rule-Based & Time-Based Access Control

- Rule-Based (RBAC): Staff specify sets of rules/conditions associated with access — such as permitted/denied IP addresses, protocols, or ports.
- Time-Based (TAC): Allows access to network resources based on time of day and day of the week.

Least Privilege & Privilege Escalation

- Least Privilege: Users should be granted the minimum access required to perform their work function. This limits the blast radius of any account compromise.
- Privilege Escalation: An exploit where vulnerabilities in servers or access control systems are used to grant unauthorized users or processes higher privilege levels.

3.2.3 Network Access Control (NAC) Systems

Automated enforcement of organizational policies across users and devices

What is NAC?

- NAC systems enforce organizational policies regarding the people and devices attempting to access the network.
- Allows cybersecurity professionals to monitor users and devices and manually control access as required.
- Without NAC, it would be impossible to evaluate the thousands of devices that could attempt network access.

NAC Capabilities

- Rapidly enforce access policies created for different operational conditions
- Recognize and profile users and devices — prevent malicious software on non-compliant systems
- Provide secure guest network access, often through registration portals
- Evaluate device compliance by user type, device type, and OS prior to permitting access
- Mitigate incidents by blocking, isolating, or repairing non-compliant devices
- Critical component of a zero-trust security architecture

3.2.4 Check Your Understanding

Test your knowledge of the access control models

Question 1

- Which access control model grants access based on attributes of the object, the subject, and environmental factors such as time of day?

→ Attribute-Based Access Control (ABAC)

Question 2

- Which access control model is based on an individual's roles and responsibilities within the organization?

→ Role-Based Access Control (RBAC) — also known as non-discretionary access control

Question 3

- Which access control model applies the strictest controls and is typically used in military or mission-critical applications?

→ Mandatory Access Control (MAC)

Summary — 3.2 Access Control Concepts

Key takeaways from Zero Trust Security, Access Control Models, and NAC Systems

3.2.1 Zero Trust Security

- "Never trust, always verify." — every access decision point is a perimeter.
- Three pillars: Workforce (people), Workloads (systems), Workplace (devices).
- Users re-authenticate for each layer — past authentication does not guarantee future access.

3.2.2 Access Control Models

- DAC (owner-controlled) • MAC (strictest / military) • RBAC (role-based) • ABAC (attribute-based)
- Rule-Based (ACL-style) • TAC (time-based)
- Principle of Least Privilege: give users only the minimum access required.
- Watch for Privilege Escalation — the exploit that breaks least privilege.

3.2.3 Network Access Control (NAC)

- Automates enforcement of access policies across all users and devices.
- Profiles devices, evaluates compliance, and blocks non-compliant endpoints.
- Essential for BYOD and IoT at scale. Core component of zero-trust architecture.